

EXPERIMENT NO. 7 — PENETRATION TESTING & VULNERABILITY SCANNING USING BURP SUITE

AIM

To familiarize students with Burp Suite for performing basic web application security testing, intercepting HTTP/HTTPS requests, analyzing web traffic, identifying potential vulnerabilities, and understanding common security issues in a controlled and authorized lab environment.

DESCRIPTION

Burp Suite is used as an intercepting proxy between a web browser and a web application. It allows HTTP/HTTPS traffic to be captured and examined so that students can understand requests, responses, parameters, headers, cookies and other web-application security information.

The experiment focuses on controlled testing of an authorized laboratory application. The captured traffic can be reviewed in HTTP History, selected requests can be examined and modified using Repeater, and controlled parameter testing can be performed using Intruder. Potential security issues can then be recorded and reviewed.

REQUIREMENTS

Category	Requirement
Software	Burp Suite Community Edition for basic proxying and manual testing
Browser	Web browser configured to use the Burp Suite proxy
Proxy	127.0.0.1 : 8080
Testing Target	Authorized laboratory or deliberately vulnerable web application
Environment	Controlled and authorized lab environment

PROCEDURE

Step 1: Installation of Burp Suite

Open a web browser and visit the official Burp Suite website and download the Burp Suite Community Edition suitable for the operating system. For Linux, download the appropriate installer. Open the Terminal, navigate to the Downloads folder using `cd Downloads`, make the installer executable using `chmod +x burpsuite_*.sh`, and run it using `./burpsuite_*.sh`. Complete the installation and launch Burp Suite Community Edition.

Step 2: Configure Burp Suite

Open Burp Suite and select **New temporary project**, then choose **Use Burp defaults** and click **Start Burp**. Burp Suite acts as an intercepting proxy between the web browser and the web application. Configure the browser proxy with the address `127.0.0.1` and port `8080` so that the browser traffic passes through Burp Suite. Testing must be performed only on an authorized laboratory application.

Step 3: Configure HTTPS Testing

For HTTPS testing, open the browser and visit `http://burpsuite`. Download the Burp CA certificate and import it into the browser's trusted certificate settings. After configuration, access the authorized test application through the browser and verify that its HTTPS traffic can be viewed in Burp Suite.

Step 4: Intercept HTTP Requests

Open **Proxy** → **Intercept** in Burp Suite and turn interception ON. Access the authorized test application and perform an action such as opening a page or submitting a test form. Burp Suite will intercept the request and display details such as the HTTP method, URL, headers, cookies, parameters and request body. Click **Forward** to send the request to the server. Interception can be turned OFF when it is no longer required.

Step 5: Analyze HTTP Traffic

Open **Proxy** → **HTTP History** to view the requests and responses captured during the session. Select a request to examine its method, URL, parameters, headers, cookies, status code and response content. This helps students understand how browser activities are converted into HTTP requests and how the web server responds.

Step 6: Repeater — Manual Testing

Select a suitable request from HTTP History and send it to Repeater. In Repeater, the request can be examined and modified using safe test values. Send the modified request and compare the server response with the original response. This helps students understand how changes in HTTP requests affect the behaviour of a web application.

Step 7: Identify Parameters

Browse the authorized application and observe the requests generated while performing searches, submitting forms, or accessing different pages. Identify user-controlled parameters present in the URL or request body. For example, in `/search?q=test`, `q` is the parameter and `test` is its value. Use only safe and non-destructive test inputs.

Step 8: Intruder — Controlled Testing

Send an authorized request to Intruder and select a suitable parameter for testing. Mark the parameter as a payload position and use a small set of safe test values. Run the test and compare the responses based on status code, response length, response time and content. Intruder should be used only within an authorized laboratory environment.

Step 9: Vulnerability Identification

Examine the authorized application for potential security issues related to authentication, session management, input validation, access control, security headers and information disclosure. Record the affected URL, observed issue, severity, possible impact and recommended security measure.

Step 10: Vulnerability Scanning

Automated vulnerability scanning is available in Burp Suite Professional. For an authorized laboratory application, configure the target scope and perform the scan. Review the reported findings carefully and verify each issue before considering it a confirmed vulnerability. Record the vulnerability name, affected URL, severity, evidence, impact and recommended mitigation.

Step 11: Review Results

Review the captured traffic in HTTP History and examine the results obtained using Repeater and Intruder. Analyze the identified security issues and record the important observations and findings in the laboratory record.

Step 12: Clear Configuration

After completing the experiment, turn Intercept OFF, restore the browser's normal proxy settings, close Burp Suite, and restore any settings changed in the laboratory application.

RESULT ANALYSIS

Burp Suite provides visibility into the communication between a browser and an authorized web application. By intercepting requests, the HTTP method, URL, headers, cookies, parameters and request body can be examined before the request is forwarded to the server.

HTTP History provides a record of requests and responses generated during the session. Repeater allows an individual request to be examined and modified using safe test values, making it possible to compare the original response with the response obtained after a controlled change.

Parameter identification helps in understanding user-controlled inputs in URLs and request bodies. Intruder can be used for controlled testing with a small set of safe values, while the responses can be compared using status code, response length, response time and content.

The experiment also demonstrates the process of identifying potential security issues involving authentication, session management, input validation, access control, security headers and information disclosure. Vulnerability findings should be reviewed carefully and potential findings should be distinguished from confirmed vulnerabilities.

RESULT

Burp Suite was successfully used to intercept, capture, and analyze HTTP/HTTPS traffic from an authorized web application. Students were able to examine HTTP requests and responses, identify parameters and security-related information, perform controlled manual testing using Repeater and Intruder, and understand the basic process of web application penetration testing and vulnerability assessment.

PRECAUTIONS

1. Perform penetration testing only on systems for which explicit authorization has been obtained.
2. Use a deliberately vulnerable application or an isolated laboratory environment for practical exercises.
3. Do not test real websites, public servers, or other users' accounts without permission.
4. Avoid destructive payloads or actions that may modify or delete data.
5. Use test accounts and test data wherever possible.
6. Keep the Burp Suite proxy disabled when normal browsing is required.
7. Do not expose captured passwords, cookies, tokens, or other sensitive information in the laboratory record.
8. Review vulnerability findings carefully and distinguish potential findings from confirmed vulnerabilities.

OBSERVATIONS

1. Burp Suite can act as an intercepting proxy between a browser and a web application.
2. The browser proxy can be configured using 127.0.0.1 and port 8080.
3. HTTP requests can be intercepted before being forwarded to the server.
4. Intercepted requests contain information such as method, URL, headers, cookies and parameters.
5. The request body can also be examined.
6. HTTP History provides captured requests and responses.
7. Response status codes and response content can be reviewed.
8. Repeater allows controlled manual testing of selected requests.
9. Safe test values can be used to compare modified and original responses.
10. User-controlled parameters can occur in URLs and request bodies.
11. The example /search?q=test contains q as the parameter and test as its value.
12. Intruder can perform controlled testing using selected payload positions.
13. Response status code, length, response time and content can be compared during testing.
14. Potential issues can involve authentication and session management.
15. Input validation and access control can also be examined.
16. Security headers and information disclosure can be reviewed.
17. Burp Suite Professional provides automated vulnerability scanning.
18. Automated findings should be reviewed and verified before being considered confirmed vulnerabilities.
19. The browser's normal proxy settings should be restored after the experiment.
20. Testing must remain within an authorized laboratory environment.

Practical Flow: Install Burp Suite → Start temporary project → Configure browser proxy → Configure HTTPS if required → Intercept request → Forward → Review HTTP History → Send selected request to Repeater → Identify parameters → Perform controlled Intruder testing → Review potential vulnerabilities → Record findings → Turn

Intercept OFF → Restore normal browser settings.